

組織要件定義書 — AWS ガバナンス基盤整備

項目	内容
文書番号	GOV-REQ-2024-001
版数	1.0
作成日	2024 年 4 月 1 日
作成部門	情報セキュリティ室 / 経営管理部
承認者	CTO 兼情報セキュリティ管掌役員

1. 会社概要と背景

ノヴァ・ソリューションズ株式会社（以下「当社」）は、社員約 800 名の中堅企業であり、自社サービスの開発・運用と、社内業務システムの内製化を進めている。事業は複数の部門にまたがり、主力の **プロダクト開発部門**、社内システムを担う **コーポレート IT 部門**、データ分析を担う **データ&アナリティクス部門** の三つが AWS を日常的に利用している。これに加えて、全社のセキュリティ・監査を担う **情報セキュリティ室** と、コスト・契約を管理する **経営管理部** が、利用部門を横断して統制側の役割を負っている。

これまで各部門が個別に AWS アカウントを開設してきた結果、アカウントが十数個に増え、命名や権限付与の方針がばらばらになり、誰がどのアカウントで何をしているのかを全社で把握できない状態になっていた。先般の内部監査で「環境（本番・検証・開発）の分離が不明確で、本番に直接変更を加えられる経路が残っている」「監査ログが一部のアカウントでしか有効化されていない」「コストの部門別把握ができていない」といった指摘を受け、経営層は **AWS Organizations を用いた全社ガバナンス基盤の再整備** を決定した。

本書は、その再整備にあたって各統制部門・利用部門からヒアリングした要望を、ガバナンス要件としてまとめたものである。当社はマルチアカウント運用を前提とし、本番・検証・開発という環境区分と、部門という組織区分の両軸で統制をかけたいと考えている。なお本書では、実現手段としての OU 階層や SCP の具体は定めない。あくまで「何を、どの対象に、どういう意図で統制したいか」を記す。

2. ガバナンスの全体方針

当社が目指すのは、**現場の開発スピードを過度に損なわずに、本番環境と全社共通の統制ラインだけは確実に守る** という形のガバナンスである。開発・検証環境では試行錯誤の自由度を比較的高く保ちつつ、本番環境では変更経路を絞り、全社で一律に守るべき最低限のルール（ログの常時有効化、利用リージョンの限定、ルート権限の保護など）はどのアカウントでも逸脱できないようにしたい。

そのために、アカウントを役割と環境で束ねて段階的に統制を当てられる構造を想定している。たとえば「全社共通で必ず守るべきこと」「本番だけに課す厳しめの制限」「開発・検証で許す広めの自由」というように、統制の強さに段階を設けたい。どの単位でアカウントをまとめ、どの段階の制限をどこに当てるかは、本書の各方針を踏まえて設計担当が決める。

統制の対象として当社が想定している軸は次の二つである。第一に **環境軸**（本番／検証／開発／サンドボックスの別）。第二に **組織軸**（プロダクト開発・コーポレート IT・データ&アナリティクスといった部門の別、および情報セ

セキュリティ室や経営管理部のような全社横断の統制部門）。加えて、セキュリティ監査用や全社ログ集約用といった**基盤・共有目的のアカウント**を、利用部門のアカウントとは性格の異なるものとして別建てで扱いたい。

3. アクセス制御に関する方針

当社では、**誰が・どの環境で・どこまで操作できるか**を環境と職務に応じて切り分けたい。最も重視しているのは本番環境の保護である。本番にあたるアカウントでは、日常的な手作業による変更を原則として認めず、変更は承認済みのデプロイ手段（パイプライン等）を通じてのみ行わせたい。開発者個人が本番に管理者権限で入って直接リソースを作り変えるような経路は、組織として塞ぎたいと考えている。

一方で、開発・検証にあたるアカウントでは、開発者が比較的自由にリソースを作成・変更できる状態を保ちたい。新しいサービスの検証や試作を妨げないことが、内製化を進める当社にとっては重要だからである。ただし自由といっても、後述する全社共通の最低ライン（利用リージョンの限定や、ルート権限・ログ設定の保護など）は開発・検証であっても外せない前提とする。

権限付与の運用面では、各アカウントのルートユーザーを日常運用に使わせないこと、特権的な操作は限られた管理者ロールに集約すること、そして部門をまたいで他部門のアカウントへ越境してアクセスできないようにすることを求める。情報セキュリティ室には、全アカウントの設定や監査ログを横断して**参照**できる読み取り中心の権限を与えたいが、利用部門のワークロードを直接変更する権限までは持たせない方針である。

4. ログ／監査に関する方針

当社は、内部監査の指摘を受けて、**全アカウントで監査ログを常時有効化し、無効化・改ざんができないようにする**ことを強く求めている。具体的には、API 操作の記録（管理イベントの証跡）や設定変更の追跡を、どの環境・どの部門のアカウントであっても例外なく有効に保ちたい。とりわけ、これらの記録自体を利用部門の担当者が止めたり消したりできてしまうと監査の意味がなくなるため、ログ取得の停止・削除に相当する操作は組織として禁止したいと考えている。

ログは各アカウントにばらばらに置くのではなく、**全社の集約先（ログ集約用のアカウント）へ一元的に集める**ことを想定している。集約されたログは情報セキュリティ室と内部監査が横断的に参照し、インシデント発生時の追跡や定期的な点検に用いる。集約用のアカウントは利用部門の手が届かない位置に置き、保全性を確保したい。

監査の運用としては、設定の逸脱（たとえばログ取得が無効化されている、想定外のリージョンでリソースが作られている等）を検知できる状態を保ち、検知されたら情報セキュリティ室が確認できる流れを求める。本書では検知の仕組みの実装までは定めないが、「ログは常に取れていて、誰も勝手に止められず、横断的に見られる」という状態を統制の到達点とする。

5. コスト／課金に関する方針

これまで部門ごとのコストが把握できず、経営管理部は予算管理と費用配賦に苦労してきた。そこで当社は、**コストを部門別・環境別に把握し、配賦と予算統制ができる状態**を求める。そのために、全アカウントに対して部門・環境・コストセンターなどを示す**タグ付けの統ルール**を徹底し、タグの付いていないリソースが放置されない運用にしたい。請求情報は全社で一元的に集約し、経営管理部が部門横断で可視化・分析できるようにする。

加えて、想定外の高額課金や、当社が利用を認めていない高コストなサービス・構成が現場で勝手に立ち上がる事態を避けたい。経営管理部としては、利用してよいサービスの範囲をある程度コントロールし、予算超過の兆候を早期に把握できるようにしたいと考えている。開発・検証環境については一定のコストは許容するが、それでも無制限ではなく、全社として「使ってよいサービス・リージョンの範囲」に収めたい。

請求・支払いに関わる設定（支払い方法や請求先情報など）は経営管理部の管理事項であり、利用部門の担当者がこれらを変更できないようにしたい。コスト関連の中枢設定は統制側に集約する方針である。

6. セキュリティに関する方針

セキュリティ面では、**全社共通で守るべき最低ライン** を、環境や部門を問わずどのアカウントでも逸脱できないようにすることを最重要とする。当社が全社一律で求める事項は次のような性格のものである。まず、利用する AWS リージョンを当社が認めた範囲（国内中心の少数リージョン）に限定し、それ以外のリージョンでのリソース作成を抑止したい。これはデータの所在を管理し、把握できない場所に資産が散らばるのを防ぐためである。

次に、各アカウントのルートユーザーや、組織のセキュリティ・監査に関わる設定（前述のログ設定を含む）を保護し、利用部門の担当者が勝手に変更・無効化できないようにしたい。保存データの暗号化やネットワークの基本的な保護といった基準も全社で標準として課したいが、その具体的な実装方法までは本書では定めず、設計担当に委ねる。

本番環境については、開発・検証よりも一段厳しいセキュリティ統制を当てたい。本番では、ネットワークを外部へ過度に開放するような構成や、全社方針に反する設定を作れないようにし、変更は承認された経路に限る（アクセス制御の方針と整合）。サンドボックス（学習・実験用）については、本番とは切り離れた別枠として扱い、本番・検証・開発の統制とは別に管理したい。

7. 環境・組織の区分（設計の手がかり）

OU 構成や統制の段階を検討する際の手がかりとして、当社が想定している区分を改めて整理しておく。

- **環境区分:** 本番 / 検証（ステージング） / 開発 / サンドボックス。本番は最も厳しく、開発・検証は自由度高め、サンドボックスは本番系から分離した別枠。
- **組織区分:** プロダクト開発部門 / コーポレート IT 部門 / データ&アナリティクス部門（いずれも利用側）。
- **横断・基盤の役割:** 情報セキュリティ室（横断参照・監査）、経営管理部（コスト・請求の統制）、全社ログ集約用アカウント、セキュリティ／監査用の基盤アカウント。これらは利用部門のワークロードとは性格が異なり、別建てで保護したい。
- **統制の段階イメージ:** 「全社共通で必ず守る最低ライン（リージョン限定・ログ保護・ルート保護など）」を全体に、「本番向けの追加の厳しめ制限」を本番系に、「開発・検証向けの広めの自由」を非本番系に、という強弱を想定。

これらをどの OU 階層に落とし込み、どの単位に SCP（許可／拒否）を当てるかは、本書の各方針（第 3～6 章）から導出して設計する。

付録: 方針サマリー（4 区分ダイジェスト）

本書第 3～6 章の方針を、区分・対象・統制意図で要約する。

区 分	対象	統制意図
--------	----	------

区分	対象	統制意図
アクセス制御	本番／開発・検証アカウント、ルートユーザー・特権ロール、部門間アクセス、監査側の横断参照	本番の直接変更を抑止し承認経路に限定。特権を集約し越境・ルート常用を防止。監査側は参照のみ許可。
ログ／監査	全アカウントの監査ログ、全社ログ集約アカウント、横断参照	ログを常時有効化し停止・削除を禁止。集約先へ一元化し保全。逸脱を検知・点検可能に保つ。
コスト／課金	全アカウントのタグ付け、請求情報の集約、請求・支払い設定、利用サービス／リージョン範囲	部門別・環境別の把握と配賦・予算統制。タグ統一徹底。請求中枢を経営管理部に集約し利用部門に変更させない。
セキュリティ	利用リージョン、ルート・セキュリティ／監査設定、全社標準、本番追加統制、サンドボックス分離	リージョンを認可範囲に限定。ルート・監査設定を保護し無効化禁止。全社標準を逸脱不能にし本番は一段厳格、サンドボックスは別管理。

以上